

4. Разграничение доступа к информации в компьютерных системах

4.1. Модели разграничения доступа к информации

Фундаментальным понятием в сфере защиты информации компьютерных систем является политика безопасности. Под ней понимают интегральную совокупность норм и правил, регламентирующих процесс обработки информации, выполнение которых обеспечивает состояние защищенности информации в заданном пространстве угроз. Формальное выражение политики безопасности (математическое, схемотехническое, алгоритмическое и т. д.) называют **моделью безопасности**.

Модели безопасности играют важную роль в процессах разработки и исследования защищенных компьютерных систем, так как обеспечивают системотехнический подход, включающий решение следующих важнейших задач:

- **выбор и обоснование базовых принципов архитектуры** защищенных компьютерных систем (КС), определяющих механизмы реализации средств и методов защиты информации;
- **подтверждение свойств** (защищенности) разрабатываемых систем путем формального доказательства соблюдения политики безопасности (требований, условий, критериев);
- **составление формальной спецификации** политики безопасности как важнейшей составной части организационного и документационного обеспечения разрабатываемых защищенных компьютерных систем.

По сути модели безопасности являются исходным связующим элементом в триаде "Заказчик (Потребитель) – Разработчик (Производитель) – Эксперт (Аудитор)". На основе моделей безопасности **заказчики** могут формулировать те **требования** к защищенным КС, которые соответствуют политике безопасности, технологическим процессам обработки информации, принятым в своих организациях и предприятиях. **Разработчики** на основе моделей безопасности формируют **техничко-технологические требования** и

программно-технические решения по разрабатываемым системам. Эксперты, основываясь на моделях безопасности, строят методики и спецификации оценки защищенности конкретных систем, осуществляют сертификацию разработанных систем по требованиям защиты информации.

Среди программно-технических методов защиты информации выделяют в первую очередь разграничение доступа. Разграничение доступа (ограничение, дифференциация, управление доступом и т.д.) непосредственно обеспечивает конфиденциальность информации, а также снижает вероятность реализации угроз целостности и правомерной доступности. Таким образом, среди других методов обеспечения защищенности информации, схематично представленных на рис. 10.1., разграничение доступа можно рассматривать как комплексный программно-технический метод защиты информации в КС и необходимое условие обеспечения состояния защищенности информации в КС.

Ввиду основополагающего значения разграничения доступа дадим формальное определение данному понятию.

Определение 1. Под *разграничением доступа* к информации в КС будем понимать разделение информации, циркулирующей в КС, на части, элементы, компоненты, объекты и т. д., и организацию такой системы работы с информацией, при которой пользователи имеют доступ только и только к той части (к тем компонентам) информации, которая им необходима для выполнения своих функциональных обязанностей или необходима исходя из иных соображений.

Содержание понятия разграничения доступа по определению 10.1. показывает необходимость изначальной разработки единой модели представления (организации) данных и разграничения доступа к ним, средствами которой можно было бы формализовать и анализировать процессы коллективного доступа к информационным ресурсам.

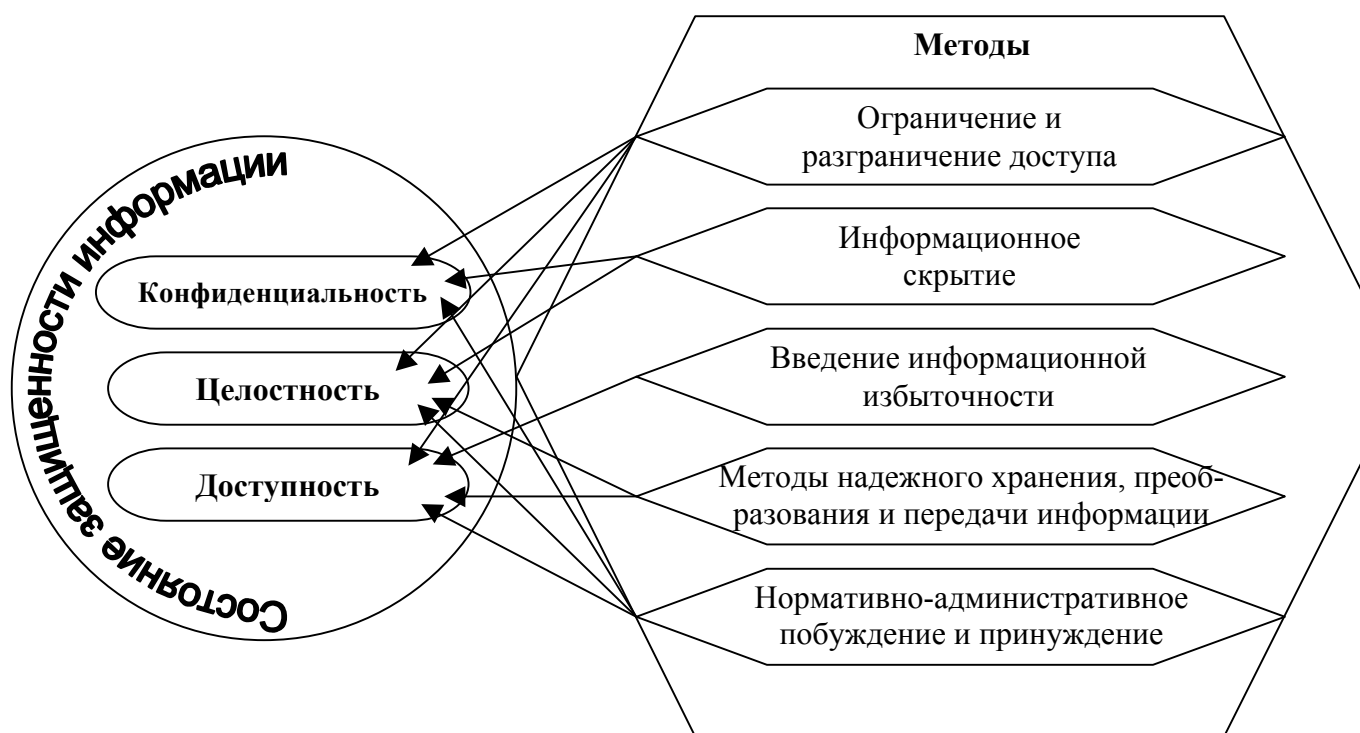


Рис. 1. Схема методов обеспечения защищенности информации в КС

Создание единых моделей представления и обработки (манипулирования) данных и разграничения доступа к данным закономерно требует исходной теоретической основы, моделирующей компьютерную систему под углом зрения процессов и механизмов коллективного доступа к информационным ресурсам.

4.2. Субъектно-объектная модель компьютерной системы в механизмах и процессах коллективного доступа к информационным ресурсам

Большинство моделей разграничения доступа основывается на представлении КС как совокупности субъектов и объектов доступа. Приведем основные положения модели.

1. В КС действует **дискретное время**.
2. В каждый фиксированный момент времени t_k КС представляет собой **конечное множество элементов**, разделяемых на два подмножества:
 - подмножество субъектов доступа S ;
 - подмножество объектов доступа O .

Определение 2. Под **субъектом доступа** понимается **активная** сущность КС, которая может изменять состояние системы через **порождение процессов над объектами**, в том числе, порождать новые объекты и инициализировать порождение новых субъектов.

Определение 3. Под **объектом доступа** понимается **пассивная** сущность КС, процессы над которой могут в определенных случаях быть источником порождения новых субъектов.

В модели предполагается наличие априорно безошибочного механизма различения активных и пассивных сущностей (т.е. субъектов и объектов) по свойству **активности**, что можно проиллюстрировать интуитивно понятными различиями между файлом с кодом программы и исполняемой (запущенной) программой, порождающей процессы над объектами системы.

Кроме того, предполагается также, что в **любой момент времени** t_k , в том числе и в начальный, **множество субъектов доступа не пусто**.

Пользователи КС представлены **одним или некоторой совокупностью субъектов** доступа, действующих от имени конкретного пользователя.

Определение 4. Под **пользователем** КС понимается лицо, внешний фактор, **аутентифицируемый** некоторой информацией, и **управляющий** одним или несколькими субъектами, **воспринимающий** объекты и **получающий** информацию о состоянии КС через субъекты, которыми он управляет.

Таким образом, в субъектно-объектной модели **понятия субъектов доступа и пользователей не тождественны**. Предполагается также, что пользовательские **управляющие воздействия не могут изменить свойств самих субъектов доступа**, что в общем случае не соответствует реальным КС, в которых пользователи могут изменять свойства субъектов, через изменение программ (исполняемых файлов). Однако подобная идеализация позволяет построить четкую схему процессов и механизмов доступа, а угрозы безопасности, возникающие вследствие подобных реалий, рассматривать в контексте гарантий выполнения политики безопасности (политики

разграничения доступа) через механизмы неизменности свойств КС (т. н. изолированная программная среда).

Субъекты КС могут быть порождены из объектов только активной сущностью (другим субъектом).

Определение 5. Объект o_i называется **источником** для субъекта s_m если существует **субъект s_j** , в результате воздействия которого на **объект o_i** возникает **субъект s_m** .

Соответственно, субъект s_j называется **активизирующим** для субъекта s_m .

Для описания процессов порождения субъектов доступа вводится следующее обозначение:

Create (s_j, o_i) $\rightarrow s_m$ – "из объекта o_i порожден субъект s_m при активизирующем воздействии субъекта s_j ".

Create называют операцией порождения субъектов. Отметим также, что ввиду того, что в КС действует дискретное время, то под воздействием активизирующего субъекта в момент времени t_k , **новый субъект порождается в момент времени $t_k + 1$** .

Результат операции *Create* зависит как от свойств активизирующего субъекта, так и от свойств объекта-источника. К примеру, субъект пользователя в виде работающего текстового редактора при открытии файла в формате другого текстового редактора может быть не способным активизировать находящиеся там **процедуры обработки данных**, а в лучшем случае быть способным только их прочесть. Другой пример – командный интерпретатор ОС **по команде пользователя не может запустить** на исполнение текстовый файл и создать таким образом субъект пользователя. В таких случаях $(s_j, o_i) \rightarrow \emptyset$.

Анализ архитектуры вычислительной системы фон Неймана, на базе которой функционируют КС, показывает, что введенное понятие субъекта доступа и процесса его порождения требует **связывания** субъекта с

определенным объектом (объектами), отражающим состояние действующего субъекта в различные моменты времени.

Определение 6. Объект o_i в момент времени t_k ассоциирован с субъектом s_m , если состояние объекта повлияло на состояние субъекта в следующий момент времени t_{k+1} (т. е. субъект s_m использует информацию, содержащуюся в объекте o_i).

Из определения 6 следует, что объект-источник в момент порождения субъекта является ассоциированным с ним, а в последующие моменты времени может перестать быть или остаться ассоциированным с ним. К примеру, исполняемые файлы программ являются ассоциированными с субъектом только в момент его порождения, так как в процессе инициализации (запуска) код программы из исполняемого файла копируется в специальную область памяти (сегмент кода), откуда впоследствии собственно и извлекаются команды-инструкции выполнения программы. Следовательно, файл на диске с исполняемым кодом программы после ее запуска перестает быть ассоциированным с субъектом, порожденным запуском программы. Напротив, в некоторых СУБД со встроенными системами программирования интерпретаторского типа команды-инструкции по обработке данных в каждый момент времени могут извлекаться непосредственно из файлов базы данных, располагаемых на диске. В этом случае, соответственно, файл базы данных продолжает оставаться ассоциированным с субъектом, порожденным открытием (запуском) соответствующего файла базы данных.

Активная сущность субъектов доступа заключается в их возможности осуществлять определенные действия над объектами, что объективно приводит к возникновению потоков информации. Исходя из этого, центральным положением субъектно-объектной модели является следующее.

Все процессы безопасности в КС описываются доступами субъектов к объектам, вызывающими потоки информации.

Определение 7. *Потоком информации* между объектом o_i и объектом o_j называется произвольная операция над объектом o_j , реализуемая в субъекте s_m и зависящая от объекта o_i .

Для описания потоков вводят следующее обозначение: $Stream(s_m, o_i) \rightarrow o_j$ "поток информации от объекта $o_i(o_i)$ к объекту $o_j(o_j)$ в субъекте s_m (через субъект s_m)"

Поток может осуществляться в виде различных операций над объектами – чтение, изменение, удаление, создание и т. д. Объекты o_i и o_j участвующие в потоке, могут быть как источниками, так и приемниками информации, могут быть как ассоциированными с субъектом, так и неассоциированными, а также могут быть пустыми ($\emptyset$) объектами (например, при создании или удалении файлов). Следует особо подчеркнуть, что согласно определению 7 потоки информации могут быть только между объектами, а не между субъектом и объектом, в виду того, что субъект это активная сущность, т. е. действия, процессы и т. д., а информация – пассивная сущность, которая может размещаться, извлекаться, порождаться, изменяться и т. д. только в объектах. Активная роль субъекта заключается в самой реализации потока, в его локализации в субъекте (через субъект), в том числе, через задействование в потоке ассоциированных с субъектом объектов (например, буферов оперативной памяти). В этом отношении более детальный анализ понятия субъектов доступа, определений 5 и 6 показывает, что ассоциированные объекты могут быть разделены на два вида:

- функционально-ассоциированные объекты;
- ассоциированные объекты-данные.

Функционально-ассоциированные объекты влияют (определяют) на сами процессы субъекта (например, состояние сегмента кода определяет свойства субъекта в следующий момент времени). Ассоциированные объекты-данные выступают в роли аргументов в операциях, порождающих потоки информации (например, буферы оперативной памяти, в которых помещается для отображения на экране информация при чтении файла).

Таким образом, если на первый взгляд в потоке участвует только один (одни) субъект(ы), то, как правило, при более пристальном взгляде можно увидеть, что в данной операции участвуют еще и ассоциированные с субъектом доступа объекты.

Определение 8. Доступом субъекта s_m к объекту o_j называется порождение субъектом s_m потока информации между объектом o_j и некоторым(и) объектом o_i (в т. ч., но не обязательно, объект o_i ассоциирован с субъектом s_m).

Формальное определение 8 понятия доступа дает возможность средствами субъектно-объектной модели перейти непосредственно к описанию процессов безопасности информации в защищенных КС. С этой целью вводится множество потоков P для всей совокупности фиксированных декомпозиций КС на субъекты и объекты во все моменты времени (множество P является объединением потоков по всем моментам времени функционирования КС).

С точки зрения процессов безопасности, трактуемой как состояние защищенности информации в КС, множество потоков P разбивается на два непересекающихся подмножества P_N и P_L :

$$P = P_L \cup P_N$$

$$P_L \cap P_N = \emptyset$$

где P_L – множество потоков, вызываемых легальными (безопасными) доступами;

P_N - множество опасных, нарушающих состояние защищенности информации (конфиденциальность, целостность и доступность информации) потоков в КС.

На основе множества потоков дается следующее понятие, составляющее основу формализации политики разграничения доступа в моделях безопасности.

Определение 9. Правила разграничения доступа субъектов к объектам есть формально описанные потоки, принадлежащие множеству P_L .

Определение 9 завершает основные положения субъектно-объектной модели КС, на методологическом фундаменте которой строится большинство моделей разграничения доступа, выражающих, собственно, подходы, принципы и механизмы правил разграничения доступа (политику разграничения доступа), а также формальные их спецификации (сами модели разграничения доступа). Ввиду того, что определение 9 не конкретизирует и не детализирует конкретных механизмов фильтрации потоков на опасные и безопасные, то можно говорить, что субъектно-объектная модель КС инвариантна относительно любой принимаемой в КС политики безопасности.

Добавим, кроме того, что во многих источниках и, в особенности, в нормативных документах по защите информации в КС, основываясь на понятии правил разграничения доступа, вводят производные термины в виде санкционированных и несанкционированных доступов.

2. Монитор безопасности и основные типы политик безопасности

Анализ практического опыта по защите компьютерной информации, а также основных положений субъектно-объектной модели КС позволяет сформулировать несколько аксиоматических условий, касающихся структуры и функционирования защищенных КС.

Аксиома 1. В защищенной КС в любой момент времени любой субъект и объект должны быть персонифицированы (идентифицированы) и аутентифицированы.

Данная аксиома определяется самой природой и содержанием процессов коллективного доступа пользователей к ресурсам КС. Если какие-либо субъекты (пользователи) имеют возможность выдать себя в КС за других субъектов (пользователей) или если имеют возможность подменять (выдавать) одни объекты доступа за другие, то ни о какой безопасности, защищенности речи быть не может. Таким образом, аксиома 1 выражает необходимое условие безопасности (защищенности) информации в КС, а

процедуры, механизмы и системы, осуществляющие идентификацию и аутентификацию пользователей, их субъектов и объектов доступа, являются исходным и важнейшим программно–техническим рубежом защиты информации в КС.

Аксиома 2. В защищенной КС должна присутствовать активная компонента (субъект, процесс и т. д.) с соответствующим объектом(ами)-источником, которая осуществляет управление доступом и контроль доступа субъектов к объектам.

В литературе для данной активной компоненты утвердился термин "*монитор безопасности*". Понятие монитора безопасности позволяет выразить схмотехнический аспект защиты информации в КС в виде схемы, представленной на рис. 2.

В структуре большинства типов программных средств, на основе которых строятся информационные системы (ОС, СУБД), можно выделить ядро (ядро ОС, машина данных СУБД), в свою очередь, разделяемое на компоненту представления информации (файловая система ОС, модель данных СУБД) и на компоненту доступа к данным (система ввода–вывода ОС, процессор запросов СУБД), а также надстройку (утилиты, сервис, интерфейсные компоненты). Инициализированные субъекты при осуществлении процессов доступа обращаются за сервисом, функциями к ядру системы – см. рис. 2.а.

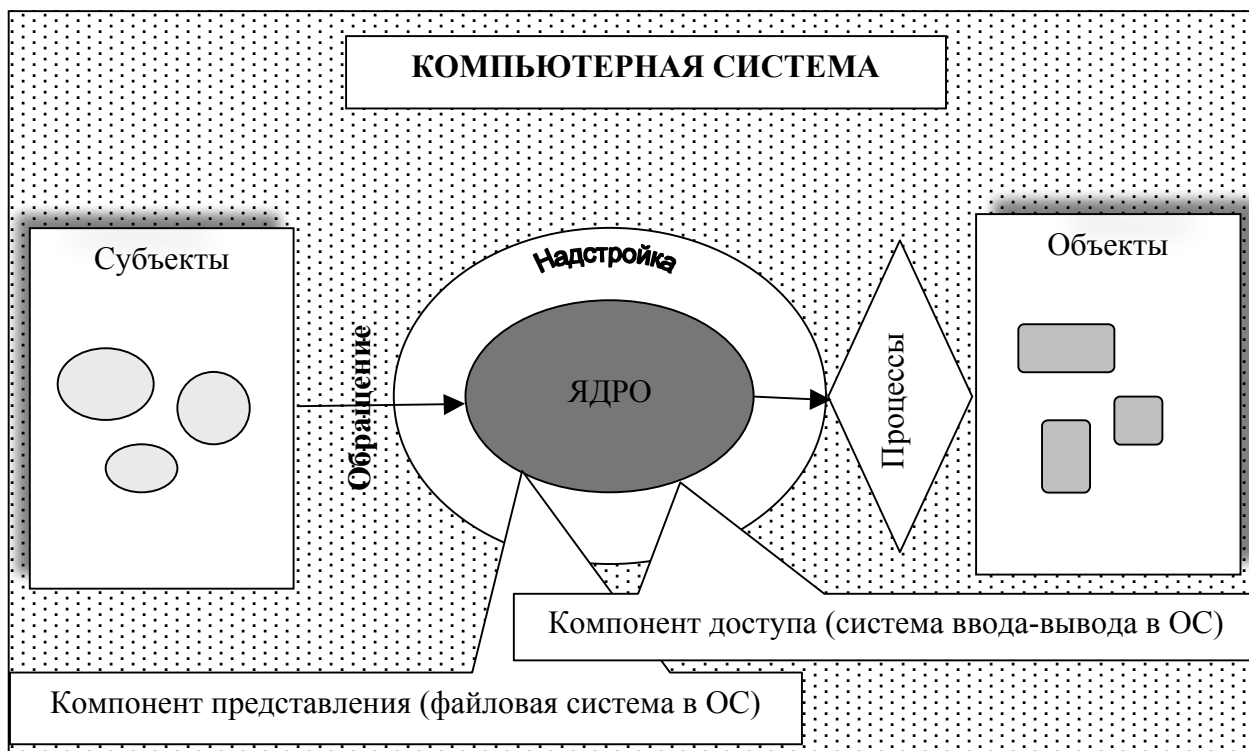


Рис. 2.а. Системотехнический аспект незащищенной КС

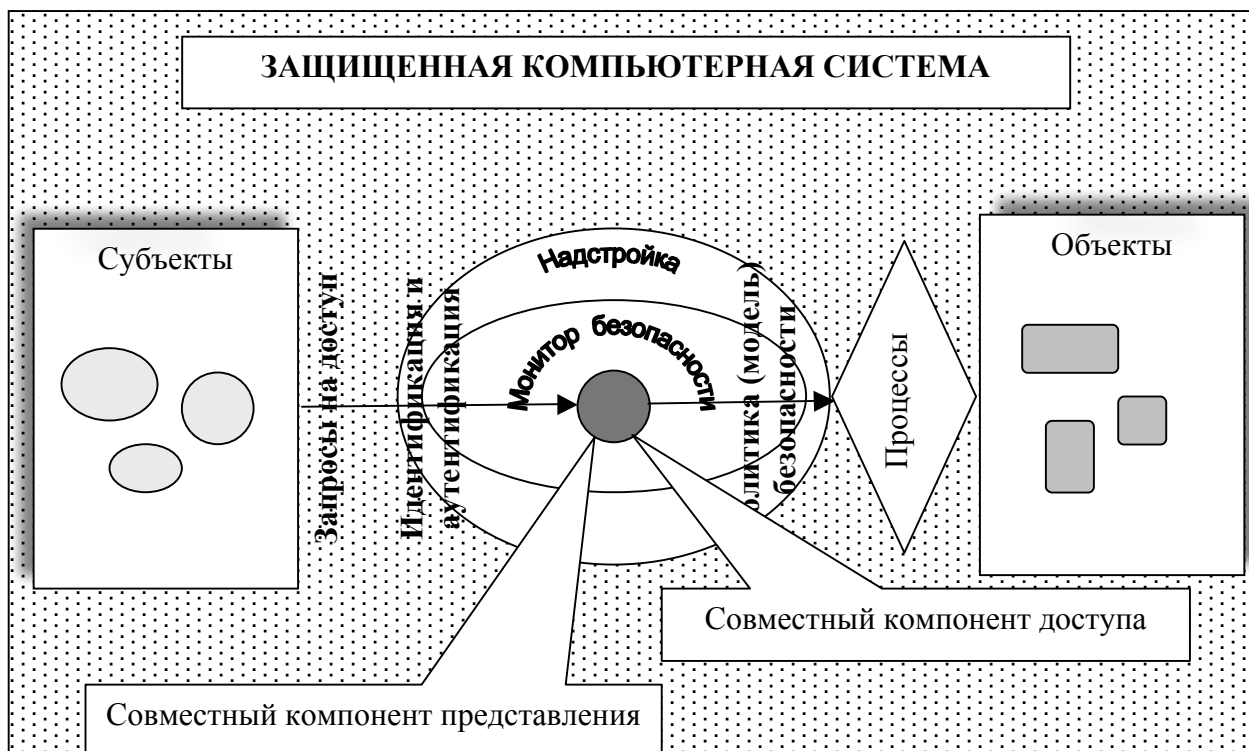


Рис.2.б. Системотехнический аспект защищенной КС

В защищенной системе появляется дополнительная компонента, обеспечивающая процессы защиты информации, прежде всего, процедуры **идентификации/аутентификации**, а также управление доступом на основе той

или иной политики безопасности (разграничения доступа) – см. рис. 2.б. Ввиду того, что как само ядро КС (компонент представления и компонент доступа), так и процессы разграничения доступа неразрывно связаны с представлением информации и манипулированием с ней, то монитор безопасности должен быть интегрирован непосредственно в ядро системы. Иногда говорят, что монитор безопасности должен быть реализован на нулевом уровне (на уровне ядра) системы. В этом отношении заметим, что более правильный подход заключается в такой разработке компонентов ядра КС, которые бы изначально строились на основе определенной модели безопасности (модели разграничения) доступа.

В практическом плане, в том числе и с учетом отечественных и международных нормативных требований по сертификации защищенных систем, к реализации монитора безопасности предъявляются следующие обязательные требования:

1. *Полнота.* Монитор безопасности должен вызываться (активизироваться) при каждом обращении за доступом любого субъекта к любому объекту, и не должно быть никаких способов его обхода.
2. *Изолированность.* Монитор безопасности должен быть защищен от отслеживания и перехвата своей работы.
3. *Верифицируемость.* Монитор безопасности должен быть проверяемым (само- или внешне тестируемым) на предмет выполнения своих функций.
4. *Непрерывность.* Монитор безопасности должен функционировать при любых штатных и нештатных, в том числе и аварийных ситуациях².

Таким образом, именно монитор безопасности в защищенной системе является субъектом осуществления принятой политики безопасности, реализуя через алгоритмы своей работы соответствующие модели безопасности. В этом отношении большое значение имеет следующее аксиоматическое положение.

Аксиома 3. Для реализации принятой политики безопасности, управления и контроля доступа субъектов к объектам необходима (должна существовать) информация и объект(ы), ее содержащий(ие) (помимо информации для идентификации и аутентификации пользователей).

Из аксиомы 3. следует, что монитор безопасности, в свою очередь, как и любая активная сущность в КС, является субъектом с соответствующим объектом-источником и ассоциированными объектами. Отсюда вытекают следующие важные следствия.

Следствие 3.1 (из аксиомы 3). В защищенной КС существуют особая категория субъектов (активных сущностей), которые не инициализируют и которыми не управляют пользователи системы – т. н. системные процессы (субъекты), присутствующие (функционирующие) в системе изначально.

К числу подобных системных субъектов относится исходный системный процесс, который инициализирует первичные субъекты пользователей, а также монитор безопасности, который управляет доступами субъектов пользователей к объектам системы. Соответственно, для обеспечения защищенности в КС свойства системных субъектов должны быть неизменными, от чего напрямую зависят гарантии безопасности.

Следствие 3.2 (из аксиомы 3). Ассоциированный с монитором безопасности объект, содержащий информацию по системе разграничения доступа, является наиболее критическим с точки зрения безопасности информационным ресурсом в защищенной КС.

Действительно возможность несанкционированно изменять, удалять данный объект может полностью разрушить или дискредитировать всю систему безопасности КС. Поэтому способы и особенности реализации данного объекта имеют определяющее значение для защищенности информации в КС.

Информация в ассоциированном с монитором безопасности объекте должна касаться конкретных зарегистрированных в системе пользователей и конкретных объектов системы. Следовательно, для планирования и

управления системой разграничения доступа конкретного коллектива пользователей КС должна быть предусмотрена процедура доступа к данному объекту со стороны внешнего фактора, т. е. через субъект(ы) пользователя. Отсюда вытекает еще одно следствие.

Следствие 3.3 (из аксиомы 3). В защищенной системе может существовать доверенный пользователь (администратор системы), субъекты которого имеют доступ к ассоциированному с монитором безопасности объекту—данным для управления политикой разграничения доступа.

Заметим также, что субъекты, иницируемые администратором системы, не являются элементами или процессами монитора безопасности, а лишь обеспечивают монитор безопасности конкретной информацией для управления и контроля доступом субъектов к объектам системы.

Принципы, способы представления и реализация ассоциированных с монитором безопасности объектов определяются типом политики безопасности и особенностями конкретной КС.

Несмотря на то, что к настоящему времени разработано и апробировано в практической реализации большое количество различных, моделей безопасности КС, все они выражают несколько исходных политик безопасности. В упрощенной трактовке политику безопасности понимают как общий принцип (методологию, правило, схему) безопасной работы (доступа) коллектива пользователей с общими информационными ресурсами. При этом согласно определению 9 важнейшее значение имеет критерии безопасности доступов субъектов к объектам, т. е. правило разделения информационных потоков, порождаемых доступами субъектов к объектам, на опасные и неопасные.

Методологической основой для формирования политик безопасности в защищенных КС послужили реальные организационно-технологические схемы обеспечения безопасности информации во вне (до) компьютерных сферах. Многие подходы к защите компьютерной информации были "подсмотрены", в частности, в сфере работы с "бумажными"

конфиденциальными документами, проще говоря, в сфере **делопроизводства**. В специальной литературе, посвященной теоретическим основам компьютерной безопасности, излагаются две основных (базовых) политики безопасности – **дискреционная и мандатная**. В еще не до конца устоявшейся терминологии сферы защиты компьютерной информации, первую называют политикой **избирательного доступа**, а вторую – политикой **полномочного¹ доступа**. Некоторые авторы, рассматривая **модели ролевого доступа**, выделяют их в группу особой "ролевой политики безопасности".

Политика дискреционного (избирательного) доступа. Множество безопасных (разрешенных) доступов P_L задается для именованных пользователей (субъектов) и объектов явным образом в виде дискретного набора троек "Пользователь(субъект)-поток(операция)-объект".

Принцип дискреционной политики разграничения доступа можно охарактеризовать схемой **"каждый-с каждым"**, т. е. иными словами для любой из всевозможных комбинаций "пользователь (субъект)-ресурс (объект)" должно быть явно задано ("прописано") разрешение/запрещение доступа и вид соответствующей разрешенной/запрещенной операции (*Read*, *Write* и т. д.). Таким образом, при дискреционной политике разграничение доступа осуществляется самым детальным образом – до уровня отдельно взятого субъекта, отдельно взятого объекта доступа и отдельно взятой операции.

Политика мандатного (полномочного) доступа. Множество безопасных (разрешенных) доступов P_L задается неявным образом через введение для пользователей-субъектов некоторой дискретной характеристики доверия (уровня допуска), а для объектов некоторой дискретной характеристики конфиденциальности (грифа секретности), и наделение на этой основе пользователей-субъектов некими полномочиями порождать определенные потоки в зависимости от соотношения "уровень допуска-поток(операция)-уровень конфиденциальности".

Таким образом, в отличие от дискреционной политики, при мандатной политике разграничение доступа производится менее детально – до уровня группы пользователей с определенным уровнем допуска и группы объектов с определенным уровнем конфиденциальности. Уменьшение гранулированности доступа создает условия для упрощения и улучшения управления доступом ввиду существенного уменьшения количества субъектов управления и контроля.

Политика тематического доступа. Множество безопасных (разрешенных) доступов P_L задается неявным образом через введение для пользователей-субъектов некоторой тематической характеристики – разрешенных тематических информационных рубрик, а для объектов аналогичной характеристики в виде набора тематических рубрик, информация по которым содержится в объекте, и наделение на этой основе субъектов-пользователей полномочиями порождать определенные потоки в зависимости от соотношения "набор тематических рубрик субъекта – набор тематических рубрик объекта".

Как и при мандатном доступе, тематический принцип определяет доступ субъекта к объекту неявно, через соотношение предъявляемых специальных характеристик субъекта и объекта и, соответственно, по сравнению с дискреционным принципом существенно упрощает управление доступом.

Политика ролевого доступа. Множество безопасных (разрешенных) доступов P_L задается через введение в системе дополнительных абстрактных сущностей ролей, выступающих некими "типовыми" (ролевыми) субъектами доступа, с которыми ассоциируются конкретные пользователи (в роли которых осуществляют доступ), и наделение ролевых субъектов доступа на основе дискреционного или мандатного принципа правами доступа к объектам системы.

Ролевая политика разграничивает доступ не на уровне пользователей-субъектов, а на уровне ролей, являющихся группами однотипного доступа к

объектам системы, и на этой основе развивает ту или иную базовую политику безопасности (дискреционную или мандатную). Поэтому в большинстве источников ролевой принцип разграничения доступом не выделяется в отдельную политику, а рассматривается в качестве **неких дополнений** к моделям дискреционного или мандатного доступа.

Каждая политика безопасности требует **определенной информации** для разграничения доступа в конкретной системе, локализуемой в объекте, ассоциированном с монитором безопасности. Для моделей дискреционного доступа эта информация представляет список разрешенных троек "субъект (пользователь) – операция – объект". Для управления доступом в системах с мандатным доступом необходима информация по уровням допуска субъектов и грифам конфиденциальности объектов. В системах ролевого доступа помимо информации, регламентирующей доступ ролей к объектам (на основе дискреционного или мандатного принципа), необходима информация по ассоциации пользователей-субъектов с ролями. При тематическом доступе необходима информация по тематическим рубрикам пользователей–субъектов и объектов.

Конкретная модель безопасности детализирует и формализует (в виде аналитических соотношений, алгоритмов, и т. д.) общий принцип разграничения доступа на основе одной из рассмотренных политик, а иногда некоторой их совокупности. В конкретной КС разработчики строят и реализуют оригинальные программно–технические решения, воплощающие модели безопасности, в том числе структуру, функции, программно–техническое воплощение монитора безопасности.

3. Гарантирование выполнения политики безопасности

Положения субъектно-объектной модели КС, в частности, понятия доступа субъектов к объектам и политики безопасности позволяют сформулировать **следующий общий критерий безопасности** КС.

Определение 10. *Компьютерная система безопасна тогда и только тогда, когда субъекты не имеют никаких возможностей нарушать (обходить) установленную в системе политику безопасности.*

Субъектом обеспечения политики безопасности выступает монитор безопасности. Его наличие в структуре КС, соответственно, является *необходимым* условием безопасности. Что касается условий *достаточности*, то они заключены прежде всего, в безопасности самого монитора безопасности.

Подтверждением данного тезиса является обязательное включение в состав спецификаций по созданию (разработке) и оценке (сертификации) защищенных КС требований *корректности, верификации, адекватности* и т. д. средств защиты информации (т. е. монитора безопасности) во всех, в том числе и отечественных стандартах и руководящих документах по компьютерной безопасности.

Приведем основные положения данной модели.

Авторами модели, прежде всего, было отмечено влияние на безопасность системы не только доступов (потоков) к объектам, осуществляемых субъектами пользователей, но и того, *какого типа субъектами пользователи осуществляют доступ к объектам*. К примеру, доступ пользователя к файлу базы данных через СУБД порождает информационный поток одного типа с определенными регламентациями-ограничениями, а доступ к тому же файлу базы данных с помощью дискового редактора – информационный поток другого типа, через который пользователь может получить не предназначенную, вообще говоря, ему информацию. При этом с формальной точки зрения политика безопасности, определяющая правомерность самого факта доступа данного пользователя к файлу базы данных соблюдается и в том и другом случае.

Отсюда следует, что правила разграничения доступа, составляющие основу политики безопасности, *должны включать и правила порождения (инициализации) пользователями субъектов доступа*.

В технологическом плане выполнение данного требования приводит к необходимости расщепления монитора безопасности на два отдельных субъекта:

- монитор безопасности объектов;
- монитор безопасности субъектов.

Вводятся соответствующие определения.

Определение 11. *Монитором безопасности объектов* (МБО) называется субъект, активизирующийся при возникновении потока между любыми объектами, порождаемого любым субъектом, и разрешающий только те потоки, которые принадлежат множеству P_L .

Определение 12. *Монитором безопасности субъектов* (МБС) называется субъект, активизирующийся при любом порождении субъектов, и разрешающий порождение субъектов из фиксированного подмножества пар активизирующих субъектов и объектов–источников.

Определение 12., по сути, вводит в состав политики безопасности КС в качестве дополнительной составной части специальную политику порождения пользователями субъектов доступа. Соответственно, как и у любого субъекта, у МБС должен быть объект-источник, функционально-ассоциированный объект (исполняемый код в оперативной памяти) и ассоциированный объект–данные, содержащий необходимую информацию по политике порождения пользователями субъектов доступа в системе – см. рис. 3.

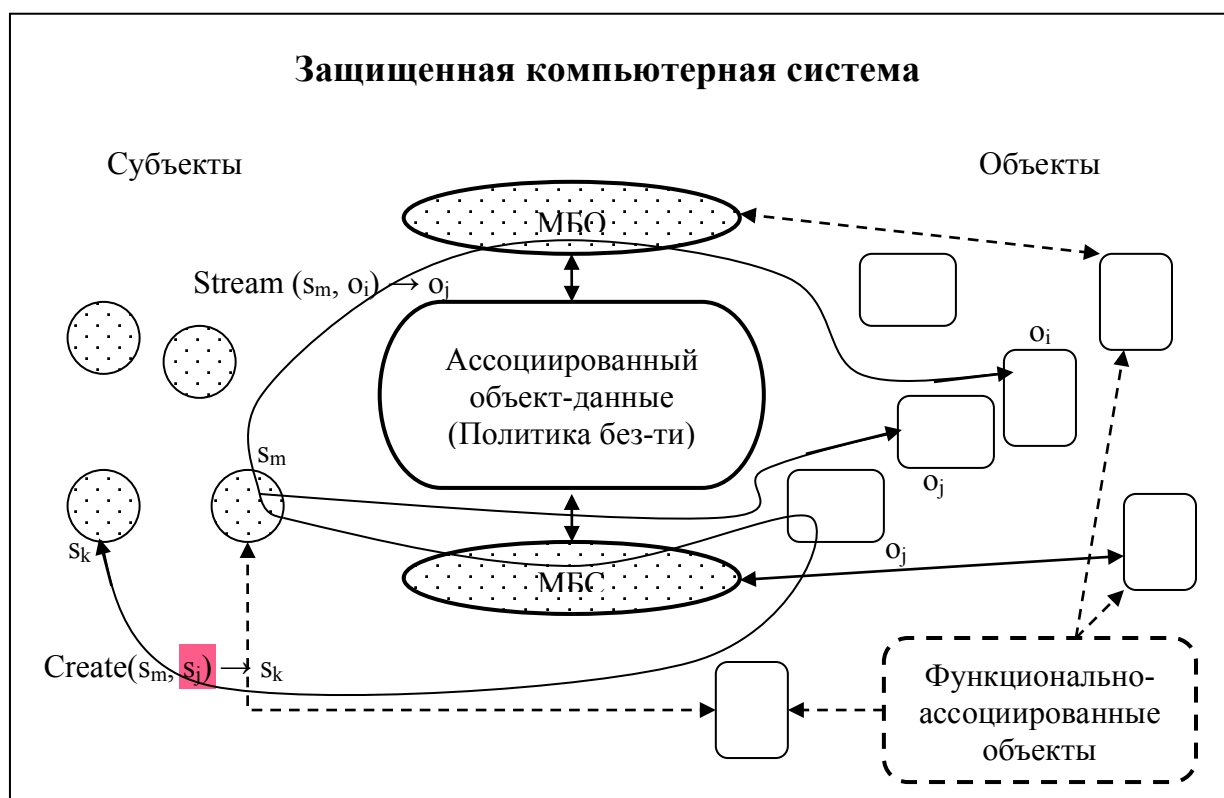


Рис. 3. Порождение потоков (*Stream*) и субъектов (*Create*) с учетом МБО и МБС

Вторым аспектом, подмеченным в плане гарантий выполнения политики безопасности, является **неизменность свойств субъектов доступа** в процессе функционирования КС. Многие известные атаки на защищенные КС как раз и осуществляются по сценарию подмены кода программ, запускаемых на выполнение регламентированных функций (т. е. фактически подмены свойств субъектов). Данное требование имеет отношение к любым субъектам доступа любых пользователей, но особо для системных субъектов, и, в частности, для монитора безопасности.

Для рассмотрения условий неизменности субъектов, вводятся следующие определения.

Определение 13. Объекты o_i и o_j тождественны в момент времени $t(o_i[t] = o_j[t])$, если они совпадают как слова, записанные в одном языке.

Тождественность объектов по определению 13. основывается не на физической тождественности, а на тождественности до уровня последовательности символов из алфавита языка представления. Для

иллюстрации понятия тождественности приведем пример эквивалентности (тождественности) двух файлов на основе побайтного сравнения, один из которых размещен на диске, другой в оперативной памяти, и находящихся, соответственно, в разной реализации по физическим процессам функционирования носителей (т. е. являющихся физически не тождественными).

Введенное понятие тождественности объектов позволяет перейти к рассмотрению понятия тождественности и неизменности субъектов доступа.

Определение 14. Субъекты s_i и s_j *тождественны* в момент времени t , если попарно тождественны все ассоциированные с ними объекты.

Определения 13 и 14 неявно требуют наличия в КС специального механизма сортировки однотипных объектов и их попарного сравнения, и, кроме того, обуславливают следующее важное следствие.

Следствие 14.1. (из определений 13 и 14). Порожденные субъекты тождественны, если тождественны все порождающие субъекты и объекты-источники.

Обоснованность данного следствия вытекает из тождества функционально-ассоциированных объектов в порождающих субъектах, которые отвечают за порождение нового субъекта, а также из тождественности аргументов операции порождения, т. е. ассоциированных объектов-данных и объектов-источников, которые определяют свойства порождаемых субъектов.

Очевидно, что субъекты, осуществляющие доступ к объектам системы, в том числе и к объектам, ассоциированным с другими субъектами, могут тем самым влиять на них и изменять их свойства. Поэтому вводится следующее определение.

Определение 15. Субъекты s_i и s_j называются *невлияющими друг на друга* (или корректными относительно друг друга), если в любой момент времени отсутствует поток (изменяющий состояние объекта) между любыми объектами o_{ik} и o_{jl} , ассоциированными, соответственно с субъектами s_i и s_j .

Причем объекты o_{ik} не ассоциированы с субъектом s_j а объекты o_{jl} не ассоциированы с субъектом s_i .

Отметим, что термин "изменение состояния объекта" в *определении 15* трактуется как **нетождественность** (в смысле *определения 13*) **объекта с самим собой в различные моменты времени**.

Анализ понятия ассоциированных с субъектом объектов позволяет ввести еще более жесткое определение по влиянию одних субъектов на других.

Определение 16. Субъекты s_i и s_j называются *абсолютно не-влияющими друг на друга* (или абсолютно корректными относительно друг друга), если в условиях определения 15 множества ассоциированных объектов указанных субъектов не имеют пересечения.

На основании данного определения можно сформулировать достаточное условие гарантированного выполнения политики безопасности.

Утверждение 1. (достаточное условие гарантий безопасности 1). *Монитор безопасности объектов разрешает порождение потоков только из множества P_L , если все существующие в системе субъекты абсолютно корректны относительно него и друг друга.*

Доказательство. Из условия абсолютной корректности любых субъектов с МБО вытекает **отсутствие потоков, которые могут изменить функционально-ассоциированные и ассоциированные объекты-данные с МБО и тем самым изменить его свойства** для осуществления обхода (нарушения) политики безопасности. С другой стороны, отсутствуют также потоки между **ассоциированными объектами и всех любых других субъектов**, и, следовательно, **отсутствует возможность изменения** одними субъектами свойств других субъектов для возможного нарушения (обхода) политики безопасности. *Тем самым утверждение доказано.*

Утверждение 1 для обеспечения гарантий безопасности накладывает чрезвычайно жесткие условия, практически **не выполнимые на практике**, или существенно **снижающие функциональные возможности** КС (отсутствие

общих объектов-источников для запуска программ разными пользователями, отсутствие общих участков памяти, буферов для обмена данными и т. п.).

Для исследования подходов, в большей степени возможных при практической реализации, вводятся понятия замкнутости и изолированности подмножества субъектов системы.

Определение 17. КС называется *замкнутой по порождению субъектов*, если в ней действует МБС, разрешающий порождение только *фиксированного конечного подмножества* субъектов для любых объектов-источников, рассматриваемых для фиксированной декомпозиции КС на субъекты и объекты.

Эквивалентным понятием для замкнутой по порождению субъектов системы является понятие *"изолированной программной среды"* (ИПС). Механизм замкнутой программной среды сокращает множество возможных субъектов до некоторого множества фиксированной мощности, но при этом не гарантирует отсутствие некорректных субъектов внутри замкнутой среды.

Определение 18. *Множество субъектов КС называется изолированным* (абсолютно изолированным), если в ней действует МБС и субъекты из порождаемого множества *корректны* (абсолютно корректны) относительно друг друга и МБС.

Из данного определения вытекают следующие следствия.

Следствие 18.1. (из определения 18). Любое подмножество субъектов изолированной (абсолютно изолированной) КС, включающее МБС, также составляет изолированную (абсолютно изолированную) среду.

Следствие 18.2. (из определения 18). Дополнение изолированной (абсолютно изолированной) среды субъектом, корректным (абсолютно корректным) относительно любого из числа входящих в изолированную (абсолютно изолированную) среду, оставляет ее изолированной (абсолютно изолированной).

На этой основе можно сформулировать другое условие достаточности гарантий выполнения политики безопасности.

Утверждение 2. (достаточное условие гарантий безопасности 2). Если в абсолютно изолированной КС существует МБО и порождаемые субъекты абсолютно корректны относительно МБО, а также существует МБС, который абсолютно корректен относительно МБО, то в КС реализуется только доступ, описанный политикой разграничения доступа.

Доказательство. По определению 18 и следствиям из него в системе могут существовать только абсолютно корректные относительно МБС и друг друга субъекты из некоторого их конечного множества. Следовательно, отсутствует возможность изменения свойств МБС. Абсолютная корректность МБС и других субъектов по отношению к МБО обеспечивает отсутствие возможностей изменения свойств МБО, что в итоге автоматически обеспечивает разрешение только тех потоков, которые входят в множество P_L . Утверждение доказано.

В отличие от первого условия достаточности гарантий выполнения политики безопасности, второе условие менее жестко, так как накладывает условия абсолютной корректности не на все множество возможных субъектов, а лишь на фиксированное их подмножество, образующее замкнутую (изолированную) программную среду (ИПС).

И все же, требование абсолютной корректности, хотя и для фиксированного подмножества субъектов, является также чрезвычайно жестким и трудно выполнимым на практике без существенного снижения функциональных возможностей КС.

Дальнейший анализ подходов к гарантиям безопасности, точнее, к возможностям реализации ИПС, показал необходимость включения требований по неизменности свойств субъектов, основанных на неких дополнительных процедурах, связанных с порождением субъектов.

Определение 19. Операция порождения субъектов $\text{Create}(s_k, o_t) \rightarrow s_i$ называется порождением с контролем неизменности объекта, если для любого момента времени $t > t_0$, в который активизирована операция порождения объекта Create, порождение объекта s_i возможно только при

тождественности объекта-источника относительно момента t_0 , т. е. при $o_m[t] = o_m[t_0]$.

Из определения 10.19. вытекает следующее важное следствие, имеющее непосредственное отношение к неизменности свойств субъектов доступа, как важнейшего условия обеспечения политики безопасности в системе.

Следствие 19.1. (из определения 19). В условиях определения 10.19. порожденные субъекты $s_1[t_1]$ и $s_1[t_2]$ тождественны, если $t_1 > t_0$ и $t_2 > t_0$. При $t_1 = t_2$ порождается один и тот же объект.

Введение понятия порождения субъектов с контролем неизменности объектов позволяет сформулировать и доказать такое достаточное условие для обеспечения ИПС, которое может быть практически реализовано в реальных КС.

Утверждение 3. (базовая теорема НПО). Если в изолированной КС, в которой действует порождение субъектов с контролем неизменности объекта, в момент времени t_0 через любой субъект к любому объекту существуют только потоки, не противоречащие условию корректности (абсолютной корректности), то в любой момент времени $t_k > t_0$ КС также остается изолированной (абсолютно изолированной).

Доказательство. Условие корректности для потоков в начальный момент t_0 времени функционирования системы обеспечивает исходную "правильность" всех объектов-источников для последующего порождения субъектов системы. Исходя из этого, и основываясь на определении 19 и следствии 19.1 из него, все последующие порождения субъектов будут происходить с неизменностью их свойств, в том числе с сохранением состояния взаимной корректности. Следовательно, в любой момент времени будут соблюдаться требования изолированности КС. Утверждение доказано.

Утверждение 3 имеет важнейшее значение с точки зрения достаточных условий для обеспечения гарантий выполнения политики безопасности в

защищенных КС. Вместе с тем, при практической реализации условий утверждения 3 также возникает несколько серьезных проблем. Одна из них, если так можно выразиться, созвучна с известной проблемой "ахиллесовой пяты". А именно, с исходным состоянием КС, в котором должны быть только потоки, гарантирующие корректность исходных субъектов.

Вторая проблема связана с понижением производительности (быстродействия) КС в связи с осуществлением процедур контроля неизменности объектов-источников при порождении субъектов.

Как уже отмечалось в следствии 3.3 из аксиомы 3., для управления конкретными параметрами системы разграничения доступа могут (должны) существовать субъекты доверенных пользователей (администраторов), имеющих доступ к ассоциированному с МБО объекту–данным. Однако рассмотренные выше условия гарантий безопасности основываются на понятии корректности (невлияния) относительно МБО и МБС всех субъектов доступа. Согласно определению 15 корректность субъектов обеспечивается их невозможностью изменять состояние всех ассоциированных с другими субъектами объектов, в том числе и объектов-данных, ассоциированных с МБО, содержащих конкретную информацию по политике разграничения доступа. Следовательно, полная и строгая реализация условий ИПС из-за невозможности впоследствии изменять ассоциированные с МБО объекты потребует изначального встраивания в систему конкретных параметров разграничения доступа (по конкретным и, соответственно, изначально зарегистрированным в системе пользователям, и конкретным, изначально созданным в системе объектам доступа), что лишает такую систему какой-либо универсальности и гибкости.